# API Security Testing Report

## Objective

Evaluate the security and validation mechanisms of the Bosta API endpoint used to update bank information.

## Tested Endpoint

POST https://stg-app.bosta.co/api/v2/businesses/add-bank-info

## Authentication Method

Bearer token generated from POST /users/generate-token-for-interview-task

## Testing Approach

Security and validation testing was performed using Postman. Various malformed and invalid inputs were submitted to identify authentication enforcement, input validation, and OTP verification mechanisms.

## Findings

### Authentication Protection

The API requires a valid Bearer token. Requests without authentication return 401 Unauthorized.

### Account Number Validation

The API enforces a minimum length of 12 characters for account numbers.

### IBAN Format Validation

The IBAN must start with 'EG' followed by 27 digits. Invalid formats are rejected.

### OTP Verification

The API requires OTP verification before updating bank information.

## Conclusion

The API demonstrates proper validation controls for authentication, account numbers, IBAN format, and OTP verification. Additional testing could include rate limiting, injection attempts, and fuzz testing.